Access Management Standard

Version 1.0

Table of Contents

1. Document Control.....1
1.1. Version Control.....2
1.2. Approval Matrix.....3
2. Introduction 4
2.1. Purpose.....4
2.2. Scope.....4
3. Standards.....4
4. Reference Policies and Industry Standards.....4
5. Governance.....4
5.1. Compliance.....4
5.2. Exceptions.....4
5.3. Review and Update.....4
5.4. Roles & Responsibilities.....4

1. Document Control

1.1. Version Control

Version	Date Published	Author	Reason for Change

1.2. Approval Matrix

Version	Approver Full Name	Approver Title	Approval Date

2. Introduction

2.1. Purpose

The 'Access Management Standard' (this standard) document defines the people, process and technology requirements that will ensure that access to company resources is controlled in line with the 'Access Management Policy'.

2.2. Scope

While this standard is applicable to all departments and users of the company and includes all resources and assets owned and/or managed by the company, not all sections may apply to all user groups. Some controls may solely be the responsibility of one user group. Such details are included in Section 3, Standards.

These requirements also apply to any and all external parties that have access to the company resources and assets, irrespective of their legal employer.

3. Standards

1. User Identity

Objective	Ensure each person using XXX Company information technology (IT) systems can be uniquely identified.
Risk implication	If identities are not unique or properly managed, the company may be unable to attribute activity to individuals or manage access rights reliably.

Requirements

Control Ref.	Requirement
1-1	Appoint a process owner to maintain the user-identity issuance process and update it when business, legal, or operational needs change.
1-2	Document a process for assigning every relevant employee and contractor a unique user identifier (User ID) for company IT systems.
1-3	Define minimum User ID attributes and naming rules so identifiers are issued consistently.
1-4	Maintain a password and authentication standard that specifies the minimum applicable security requirements.
1-5	Document the User ID lifecycle process. At minimum, it must identify: (a) who may request and approve an ID; (b) how requests are submitted; (c) which roles may initiate requests; (d) who creates IDs and assigns access; (e) who approves requests; (f) how access is linked to job role, location, or other approved criteria; (g) whether standard account templates are used; (h) how credentials are delivered securely; (i) how an ID is disabled; (j) target times for creating or disabling an ID; (k) target times for removing associated access; (l) target times for deleting an ID where appropriate; and (m) how issuance records are protected and retained.
1-6	Assign each person a unique User ID. Generic or shared user identities must not be used for routine individual access unless a documented, approved exception applies.

1-7	Log changes to user identities and retain the audit records for the period defined by the company's records-retention requirements.

2. User Authorisation

Objective	Ensure users receive approved access to company IT systems and resources.
Risk implication	Without suitable authorisation, users may gain access to information or functions that are not appropriate to their duties or approved responsibilities.

Requirements

Control Ref.	Requirement
2-1	Appoint a process owner to define how user access is authorised before access rights are granted.
2-2	Document the access-authorisation process. It must cover: (a) how requests are made and approved; (b) linking permissions to individually identifiable users; (c) default access assigned to users; (d) pre-approved standard access profiles for defined roles; (e) need-to-know, need-to-use, least-privilege, and segregation-of-duties principles across relevant systems; (f) preventing retired or redundant identifiers from being reassigned inappropriately; and (g) handling exceptional cases where normal access controls cannot be used.
2-3	Obtain approval from the relevant system, data, or business owner before applying access authorisations.
2-4	Maintain an accurate register or repository of authorised users and their access rights, with updates restricted to authorised personnel.
2-5	Protect access registers against unauthorised viewing, alteration, disclosure, or deletion using appropriate logical and physical safeguards.
2-6	Review user access periodically to confirm it remains appropriate, remove unnecessary permissions, and address role changes or departures. As a proposed baseline, review standard users at least annually, elevated access at least every six months, and access to critical systems at least quarterly.
2-7	Configure systems to end user sessions automatically when defined conditions are met, including inactivity timeouts where appropriate.
2-8	Maintain a central register of current and former authorised users, subject to applicable retention requirements.
2-9	Apply logical and physical protections to the central user register to prevent unauthorised access, modification, or disclosure.

3. User Authentication

Objective	Require secure authentication before users access XXX Company IT systems.
Risk implication	Weak or absent authentication may allow impersonation, circumvention of access controls, or access to systems and information without proper authority.

Requirements

Control Ref.	Requirement
3-1	Require each user to authenticate to relevant company systems using a unique identifier and approved authentication factor or factors.
3-2	Configure authentication controls so that: (a) the required sign-in information is collected before validation; (b) secrets are obscured during entry; (c) repeated unsuccessful attempts trigger a defined protective response; (d) authentication information is stored and processed securely, using cryptographic protection where appropriate; and (e) sign-in attempts are logged securely.
3-3	Define and enforce rules for the secure handling of User IDs, passwords, tokens, and other authentication factors.
3-4	Review authentication and access logs periodically for suspicious patterns, including repeated attempts using the same account or concurrent sign-ins from different locations or devices.
3-5	Set workstation password requirements in line with the company's approved authentication standard and current security guidance. Requirements should address password length, resistance to guessing, reuse, secure generation, and any rotation rules justified by risk or applicable requirements.
3-6	Change vendor-default credentials before a new system or device is placed into production.
3-7	Disable, remove, or securely rename default, unused, and unnecessary accounts on systems, databases, applications, network devices, and workstations.
3-8	Require company-approved multi-factor authentication for access to high-risk or sensitive environments, including privileged accounts and critical systems, and for other systems identified through risk assessment.

4. Segregation of Duties

Objective	Prevent inappropriate combinations of access rights by separating incompatible responsibilities.
Risk implication	Insufficient separation may enable unauthorised transactions, fraud, mistakes, or activity beyond a user's authority.

Requirements

Control Ref.	Requirement
4-1	Identify and document business activities and access combinations that require separation of duties.
4-2	Consider, at minimum, conflicts involving: (a) operating business applications, systems, and networks; (b) designing, developing, and testing those systems; (c) designing, implementing, and independently assuring controls; (d) developing, reviewing, and operating code or configurations; (e) access to development, test, user-acceptance, and production environments; (f) initiating and approving sensitive transactions; (g) requesting, approving, and provisioning access; and (h) requesting, approving, and implementing IT changes.
4-3	Document access-control and segregation arrangements with regard to data classification, system-owner requirements, contractual commitments, and applicable legal and regulatory obligations. Include individual accountability and additional safeguards for elevated access.
4-4	Review segregation-of-duties arrangements at least annually for standard users and more frequently for privileged users; a proposed baseline for privileged users is quarterly.
4-5	Remove or adjust access rights promptly when a confirmed conflict violates approved segregation requirements.
4-6	Investigate how a segregation-of-duties conflict occurred and determine whether corrective action is required.
4-7	Update segregation rules and their enforcement when an investigation or business change identifies a gap.

5. Access Management

Objective	Manage standard-user permissions so they remain appropriate to each user's duties.
Risk implication	Excessive or poorly defined permissions may allow users to access, change, extract, or delete information or perform functions outside their approved responsibilities.

Requirements

Control Ref.	Requirement
5-1	Appoint an owner for the standard-user access-provisioning process.
5-2	Document the process for requesting, approving, granting, changing, maintaining, and removing access to company systems and applications.
5-3	Ensure the access-provisioning process specifies: (a) how requests and changes are submitted; (b) who may request access; (c) who approves it; (d) who creates accounts and assigns permissions; (e) how permissions are linked to a defined role; (f) how access is provided; (g) how access is communicated or issued securely; (h) how access is revoked; (i) target times for granting, changing, or revoking access; and (j) how access decisions and changes are recorded and protected.
5-4	Review system permissions at least annually to confirm they remain appropriate to users' roles and responsibilities.
5-5	Have the system owner review access and relevant user activity at least annually to confirm that both remain appropriate and valid.
5-6	Check user permissions against the company's segregation-of-duties rules during access reviews.
5-7	Configure user permissions according to least privilege, granting only the access required for approved duties.
5-8	Identify inactive application accounts and disable them after a defined inactivity period, taking account of approved exceptions and checking with the relevant business owner where necessary.
5-9	Restrict administrative access to management networks or designated management zones where technically feasible and appropriate to the environment.
5-10	Operate a joiner-mover-leaver process: (a) grant new users approved role-based access; (b) review and adjust permissions when users change roles; and (c) disable access promptly when employment or engagement ends.

6. Privileged User Access Management

Objective	Control elevated and administrator access to XXX Company IT systems.
Risk implication	Poorly controlled privileged access can expose sensitive information, enable unauthorised system changes, or disrupt normal operations.

Requirements

Control Ref.	Requirement
6-1	Use an appropriate privileged access management (PAM) capability to control and, where feasible, provide time-limited privileged sessions to systems such as servers, databases, and logging platforms.
6-2	Appoint an owner for the process used to request, approve, issue, and provision privileged accounts.
6-3	Document the privileged-access process, including: (a) how requests or changes are submitted; (b) who may request privileged IDs; (c) who approves the request and the privilege level; (d) who creates the account and assigns rights; (e) how rights are mapped to an approved role; (f) how access is issued; (g) how it is revoked; (h) target times for granting, changing, or removing access; (i) how the decision is recorded and protected; and (j) how often privileged access is recertified.
6-4	Define and implement a distinct naming convention and separate identifiers for privileged accounts.
6-5	Use a standard account template to apply consistent attributes to privileged identities.
6-6	Assign each privileged user a separate privileged ID that is distinct from their ordinary user account.
6-7	Set stronger safeguards for privileged credentials in the approved authentication standard, addressing length, resistance to guessing, reuse, personal information, secure storage, and rotation where appropriate.
6-8	Identify and document the activities and tasks that require privileged access.
6-9	Perform privileged tasks using the designated privileged account rather than an ordinary user account.
6-10	Require privileged users to use their assigned privileged identity whenever performing privileged operations.
6-11	Record privileged accounts in the approved PAM system or equivalent controlled inventory.
6-12	Limit privileged access to named individuals who need it for their assigned responsibilities.
6-13	Log privileged-account activity. Where supported and appropriate, records should include the account used, sign-in time, source address, actions performed, and sign-out time.
6-14	Store privileged-access logs in a protected location and limit access to authorised personnel using suitable logical and physical controls.
6-15	Retain privileged-access logs in accordance with the company's logging and records-retention requirements.
6-16	Review privileged-access logs regularly; a proposed baseline is monthly review for evidence that privileged credentials are being used appropriately.
6-17	Have line management recertify privileged access at least every six months, confirming, changing, or revoking permissions as appropriate.
6-18	Restrict direct privileged database access to authorised database administrators and, where feasible, use approved applications or controlled access paths. Apply need-to-know and need-to-use principles.

7. Technical Account Access Management

Objective	Manage machine, service, application, and other non-human accounts used by company systems.
Risk implication	Unmanaged technical accounts may be compromised, misused, or retain unnecessary access, creating security risks similar to those associated with user accounts.

Requirements

Control Ref.	Requirement
7-1	Appoint an owner for the process and standard used to create and provision technical accounts.
7-2	Define a technical-account template to ensure consistent account attributes and configuration.
7-3	Establish a naming convention that clearly distinguishes technical accounts from ordinary and privileged user accounts.
7-4	Configure technical-account defaults to: (a) prevent interactive sign-in unless specifically justified; (b) manage credential expiry according to the approved secret-management approach; (c) block unrelated productivity, browsing, communication, internet, or collaboration access unless required; (d) grant only documented and approved least-privilege permissions; (e) identify the owning business unit and accountable owner; and (f) assign a unique identifier following the naming convention.
7-5	Assign an accountable owner to each technical account. The owner must request its creation and access, ensure required credentials are stored in an approved secure repository, review use and access at least annually, and request removal when the associated asset or service no longer requires the account.
7-6	Document the permissions assigned to each technical account.
7-7	Require appropriate management approval for technical-account permissions and apply additional safeguards where risk warrants.
7-8	Log the use of technical accounts where supported by the system and proportionate to risk.
7-9	Protect technical-account logs in a secure location and restrict access to authorised personnel.
7-10	Retain technical-account logs in accordance with the company's logging and records-retention requirements.
7-11	Have the relevant business unit and account owner review technical-account activity and permissions at least annually.
7-12	At least annually, confirm whether each technical account remains necessary and retain, modify, disable, or remove it accordingly.
7-13	Restrict hard-coded credentials to approved exceptional cases where technically necessary, limit who can manage them, and apply compensating safeguards and a remediation plan where possible.

8. Remote Access Management

Objective	Provide controlled remote access to XXX Company networks and systems.
Risk implication	Insecure remote access may expose company systems and information to unauthorised users or external threats.

Requirements

Control Ref.	Requirement
8-1	Appoint an owner for the process governing remote access by personnel and approved third parties.
8-2	Document the remote-access process and its approval, configuration, monitoring, and removal requirements.
8-3	The remote-access process must specify: (a) permitted device types; (b) how new requests and changes are submitted; (c) how risk is assessed; (d) who may request access; (e) who may approve it; (f) how access rights are assigned; (g) how accounts and required software are issued; (h) how access is revoked; (i) target times for granting, changing, or removing access; and (j) how access decisions and software issuance are recorded and protected.
8-4	Review remote-access permissions at least annually to confirm they remain consistent with users' roles and responsibilities.
8-5	Apply least privilege to all remote-access permissions.
8-6	Protect remote connections using encryption in transit and multi-factor authentication, subject to approved exceptions supported by risk assessment and compensating controls.
8-7	Log remote-access activity and retain records in accordance with the company's event-logging and monitoring requirements.
8-8	Review remote-access permissions and activity at least annually to confirm that access remains appropriate and valid.
8-9	Disable inactive remote-access accounts through the company's unused-account review process.
8-10	Configure remote-access services to: (a) disconnect sessions after the approved inactivity period; (b) enforce a defined maximum connection duration where appropriate; (c) use an approved VPN or equivalent secure access method; (d) require approved multi-factor authentication; and (e) bind authentication tokens to individual users.
8-11	Apply risk-based organisational and technical controls to restrict remote access to critical systems from locations or networks that the company has not authorised.
8-12	Detect and control concurrent remote sessions where simultaneous connections could increase risk or breach company requirements.

4. Reference Policies and Industry Standards

- **Access Management Policy**
- **Information Security Policy**
- **ISO27001:2022**
- **General Data Protection Regulation**

5. Governance

5.1. Complaince

Compliance to this standard is critical for all users within access to organisational resources and assets. It may be acceptable if a certain requirement can be met using alternate methods. However, the alternate method must be reviewed and agreed by the cybersecurity team.

Non-compliance to this standard may result in disciplinary action, including but not limited to, access suspension, termination of employment, or legal consequences.

5.2. Exceptions

Any questions, issues or exceptions related to use of compliance to this standard should be raised to the Cybersecurity team

5.3. Review and Update

This Standard will be reviewed at a minimum on an annual basis or at the time of any significant changes to company operations or developments in the technological ecosystem or related policies.

5.4. Roles & Responsibilities

- All employees must be aware of their responsibilities for protecting confidential and sensitive information and must take all necessary steps to safeguard the privacy and security of organisational information and assets.
- Managers and supervisors are responsible for ensuring that their teams are aware of and comply with these requirements. They must

report any violations of this standard, for example, those relating to contractors and service providers, immediately to leadership.